Federal Office
for Information Security

BSI publications on cyber security

RECOMMENDATION: IT IN PRODUCTION

Monitoring and Anomaly Detection in Production Networks

Is this normal?

Today's modern production networks feature a topology comparable to conventional IT networks and increasingly use protocols that are also based on TCP[1]/IP[2]. These protocols are addressed not only by intelligent control devices; sensors and actuators are using them to communicate more and more often, as well. The sheer number of such components and the connections among them are resulting in networks of ever greater complexity. Industrial network elements and segments are connected by switches, while firewalls and other monitoring solutions are deployed to safeguard the edges of network segments and the gateways that link them. In this context, monitoring involves logging and analysing the data and flows thereof in a given network, which mainly aids in identifying anomalies that can impact technical and business concerns. Functionality, quality, availability, safety[3] and security[4] are some examples of the areas that can be affected. The industrial networks of today are similar in structure (and often connected) to office IT networks. The threats this presents, which are comparable to those faced in conventional IT, require a focus on security. While using IT components from traditional office settings in production networks offers advantages in terms of costs, operations and user-friendliness, they also present more points of attack [see[1]]. This makes monitoring and anomaly detection essential with regard to prevention, detection and response.

This cyber security recommendation explains the basic principles of monitoring and anomaly detection and also offers assistance in selecting related products.

1 Monitoring

Monitoring is a collective term for all types of direct and systematic identification, observation, or supervision of a process using technical resources or other corresponding systems (see [2]).

Employed in virtually every area of the economy, industry, environment and many

1 TCP: Transmission Control Protocol, part of the Internet protocol suite
2 IP: Internet Protocol
3 Safety: in terms of physical and operational safety
4 Security: in terms of protecting information and thwarting attacks

other realms, monitoring can be applied to all manner of procedures. It represents an expansion of logging on a more profound level.

In information technology, monitoring involves continuous observation of processes, devices, communication links and services within a given network. Along with the data transmitted over the network, this includes the log data [3] generated by network components (such as switches or firewalls). Monitoring is implemented by means of appropriate hard- and software.

In industrial environments, and thus in the context of this publication, monitoring is not limited to mere status monitoring (conditions, processes, alarms). It also covers the observation of communications transmitted among automation components, to actuators and sensors, and to and from remote components. This involves triggering notifications and alarms when events of significance are detected, as well. In addition, management and control systems such as MES[5], ERP[6]and historians must be taken into account.

2 How does Monitoring work?

In most cases, monitoring is an independent process that is meant to oversee all the devices in a given network regardless of their type, purpose and manufacturer. Data and information are collected in one or more central locations (or requested from a central location), analysed using technical procedures and presented in the form of status reports. Monitoring solutions also make it possible to establish thresholds, which means that such status reports can range from simple signals (red or green lights once a threshold has been reached, for example) to complex diagrams, statistics and risk assessments. This helps ensure network transparency.

To make efficient use of monitoring, it is necessary not only to choose a suitable solution, but to analyse the processes to be monitored and define corresponding criteria, as well.

3 Anomalies

Anomalies are unexpected deviations from corresponding rules (see [4]) – or, in the context of production, from “normal operating conditions”. They usually arise when an error occurs, but can also be an indication of an attack or a form of manipulation within a production network. This is particularly true when events happen for the first time, processes exhibit abnormal behaviour, or devices begin communicating with one another despite not having done so before. Analysing anomalies thus makes it possible to detect attack patterns, including those that are not yet known. This makes anomaly detection a suitable technique for determining operational conditions, generating warnings and performing more effective forensics when necessary. Anomaly detection is one of the basic methods of intrusion detection (see[5]). That said, it is not a static system that acts based on fixed or known threat patterns (like indexed computer viruses, for example). Instead, anomaly detection continually re-evaluates the standard communications of the network at hand, which facilitates dynamic adjustments to changes in threat vectors. This in turn enables such systems to detect behaviour patterns that have not yet been seen in the network or registered on virus or error status lists.

5 MES: manufacturing execution system
6 ERP: enterprise resource planning systems, which also map business processes

4 What are anomalies?

In production networks, anomalies are a dynamic category of potentially disruptive factors. They include the following factors, among others:

- Unusual or exceptional activities in a network (including ICS[7])
  - Connection of a new device
  - DHCP[8] requests
  - Data packets from an as-yet unknown device
  - Data transmission between devices that have not previously communicated
  - Data transmission via a protocol that has not been used before
  - Data transmission via an unusual protocol or one not intended for the purpose at hand
  - Events that occur at unusual times
  - Use of unexpected addresses (public IP addresses, etc.)
  - Generally noteworthy events such as address or port scans
  - Changes in network quality, including high broadband usage, increased round-trip times and smaller TCP window sizes
- Abnormal events in logs typical of production environments (including ICS)
  - Unusual error messages
  - Unsupported function calls
  - Function calls that have not been used before
  - Flawed data packets
  - Unknown function codes
  - Abnormal protocol behaviour
  - Unexpected transition from one protocol to another
- Unusual changes in process data (sensor data, control data, etc.)
  - Values outside of defined ranges
  - Changes in frequency
  - Changes in cycle times
  - Changing variance within certain periods of time

5 How does Anomaly Detection work?

To identify anomalies, the normal state of a system – in this case, a production network – must first be known. To that end, passive sensors (ideally, passive network or wire taps) are introduced to the network or network segment at hand as a means of collecting data on the network over an extended period of time (the “training phase”). Alternatively, a switch with port mirroring can also be used. In this context, data includes all the IT-related signals transmitted on the network (usage and logging data, packet data, and so on). The system gathers all the information that arises, which enables it to learn the network’s topology, the communication

7 ICS: industrial control system
8 DHCP: Dynamic Host Configuration Protocol (automatic assignment of names to network addresses)

links and time-related behaviours at hand, and (if applicable) the content of communications. The data acquired can be analysed, categorised and evaluated based on a wide variety of criteria. This serves as a basis for defining thresholds and trigger points that will make it possible to identify conditions and processes that deviate from the normal states the system has learned to recognise. Since every event that occurs for the first time will be considered an anomaly, it helps to establish potential problem areas before and during the training phase in order to pay particular attention to them and reduce the number of false positives reported. During live operations, these initial settings then need to be continuously adjusted – when expansions lead to the addition of new devices, for example, or the time behaviour of a given communication link undergoes a deliberate change. This requires ongoing observation and assessment. After all, potential attackers will be intent on disguising their activities as normal operating behaviour.

In accordance with its purpose, a detection system needs to be integrated into the network to be monitored as an independent, stand-alone component that has interfaces to signalling, notification and alarm systems, and other active security components.

6 Required Features of Anomaly Detection Systems

In accordance with the examples of anomalies presented in Section 4, it is possible to define several categories of requirements that an anomaly detection system should meet to the greatest extent possible.

6.1 Category: general requirements

- Overview of all devices that communicate in the network
- Identification of all the protocols used in the network
- Identification of all the communication links in the network
- Monitoring of network load over time (data volume, communication time, etc)
- Configuration of adjustable detection criteria
- Definition of multiple escalation levels
- Adjustable, clearly arranged means of visualisation
- User-friendly notification and presentation of events
- Presentation of event correlations
- Support for integration into existing signalling, notification and alarm systems
- Scalability (e.g. support for additional storage capacity)
- Statistics
- Filter functions
- Export functions for further analysis (e.g. anomaly-specific network records, including for forensics where applicable)
- A model of users and roles for system access
- Support for updates
- Internal logging functions

6.2 Category: unusual or exceptional activities in a network (including ICS)

Basic requirements:

- Identification of new devices in ICS networks
- Identification of communications taking place between two devices that have not previously communicated
- Identification of communications taking place between two devices via a TCP/UDP[9] port that has not previously been used
- Identification of new protocols or changes in protocol among individual components
- Identification of connections to insecure networks (e.g. the public Internet)
- Identification of insecure communication attributes (e.g. a lack of encryption)

Additional requirements:

- Identification of fluctuations in data volume and frequency
- Presentation of unusual activities
- Detailed presentations (with drill-down options[10] where applicable)
- Assessment of the relevance and risk presented by detected anomalies

6.3 Category: abnormal events in logs typical of production environments (including ICS)

Basic requirements:

- Identification of error messages, including (for example):
  - Invalid or unsupported function calls or function codes
  - Invalid addresses or destinations
- Address or destination unavailable / cannot be reached (e.g. timeouts)
- Identification of ICS-specific function codes that have not previously been used
- Identification of format errors in ICS logs
- The ability to determine whether an access attempt (e.g. read/write) pertains to an address that is not normally used by the device at hand

6.4 Category: unusual changes in process data (sensor data, control data, etc.)

Basic requirements:

- Deviations within defined value ranges
- Changes in frequency
- Changes in time-related behaviour
- Changes in tendency within certain value ranges

9 UDP: User Datagram Protocol, part of the Internet protocol suite
10 Drill-down options: incremental functions that enable users to refine information down to varying levels of detail

7 Active or passive?

Active and passive solutions for monitoring and anomaly detection differ in terms of whether they collect the data required non-interacting (passive) or create data themselves in the monitored network (active). The latter can take place by means of a solution's own requests in the network; mechanisms for detecting new participants in the network; or active querying of system conditions, firmware versions and log data. The terms "active" and "passive" refer in particular to the sensors used for data collection and system connectivity in a given network.

7.1 Active systems

Active systems produce data transmissions in the network to be monitored. Such transmissions contain (for example):

- Log data queries
- Queries regarding device types, firmware versions, system states and measurement data
- Pings or ARP requests meant to check a network segment for current participants

As a rule, active systems rarely require interventions in a given network, if they do at all; they are incorporated via existing access points. The mirror ports of existing switches can also be used for collection purposes. The system at hand must then be configured such that the data it generates itself can be distinguished from the data to be monitored. Effects on time-related behaviour in the network segment in question may also need to be taken into account. An attacker capable of manipulating data in a given network can, of course, also influence the monitoring system in place. Meanwhile, production networks are often time-sensitive, where data needs to be transmitted according to defined time slots. Additional data packets can lead to deviations and cause workflow disruptions. In typical heterogeneous production networks where some firmware and hardware has not been updated in a very long time, active querying can itself pose a risk to stability; this should therefore be considered, as well. In addition, active systems should support the protocols of other active devices in the network at hand and must not adversely affect the warranties of the equipment present.

7.2 Passive systems

Passive systems make use of network or wire taps in a manner that has no effect on data or time-sensitive behaviour in the network at hand. They are also not used to transmit data into the network. In some situations, the network itself or a particular network path must be segregated in order to install network or wire taps. As a result, it should only be done at an appropriate time, such as prior to commissioning or during a maintenance window. Devices cannot be queried using passive network sensors.

8 Conclusion

The terms "monitoring" and "anomaly detection" are typically used interchangeably. Upon closer inspection, however, they are two activities that build on one another. Indeed, monitoring establishes a foundation on which anomalies can be identified during further observation. This means that the differences between the two activities, which largely employ the same methods and mechanisms, are not clearly defined.

Monitoring first provides for transparency with regard to the participants and communication links in a given production network, which enables it to serve general commissioning and maintenance purposes, as well. As an oversight solution, monitoring is a suitable means of checking whether processes meet defined standards of behaviour and identifying deviations from established patterns.

Anomaly detection, meanwhile, is a tool for protecting all types of networks. It makes it possible to identify atypical behaviour, which is useful not only in connection with technical errors and flawed configurations, but in detecting as-yet unknown forms of network attacks. This sets anomaly detection apart from other measures that rely on the identification of threats that are already known.

Along with technical systems for monitoring and anomaly detection, other technical and organisational processes are necessary to evaluate the results and notifications such systems provide and take appropriate action in response.

Due to the apparent increase in attacks on networks in the realms of production and critical infrastructure, ways to detect incursions like these are more essential than ever. At the same time, such measures have to accommodate complex structures, which is why they require corresponding systems. Monitoring and anomaly detection should not, however, be implemented as stand-alone security solutions, but in combination with other protective measures. In accordance with ISO/IEC 27001[6] [7] (and thus with ISO/IEC 62443-4-2[8]), monitoring is a component of "information and security management systems" (ISMS).

9 Additional information

Among other documents, "Top 10 ICS Threats and Countermeasures" is recommended as further literature on the cyber security threats to industrial systems. The BSI's ICS Security Compendium offers a basic introduction to securing control mechanisms and industrial equipment, while the BSI standards 200-1 to 200-3 (and the corresponding IT-Grundschutz modules) provide more in-depth information. These and further documents are available at:

https://www.bsi.bund.de/ICS

Questions, suggestions and notes regarding this recommendation can be sent to the following e-mail address:

ics-sec@bsi.bund.de

By means of the BSI publications, the Federal Office for Information Security (BSI) publishes documents about current topics in the field of cyber security. Comments and advice from readers can be sent to **info@cyber-allianz.de**.